



Compliance Readiness Guide for SEC, FINRA, and HIPAA Examinations

What regulators are actually looking for — and how to be ready before the notice arrives.

Understanding Regulatory Examinations

Regulatory examinations are not random audits. They follow specific methodologies:

- SEC OCIE Examinations: Focus areas published annually, technology governance increasingly prominent.
- FINRA Cycle Examinations: Risk-based scheduling with technology controls as a standing priority.
- HIPAA Audits: OCR-initiated investigations often triggered by breach notifications.
- State Regulators: Increasing focus on cybersecurity and data protection requirements.
- Examination frequency increases after findings or industry-wide enforcement actions.

What Examiners Look For

Across all regulatory bodies, examiners evaluate consistent themes:

- ✓ Written Policies: Current, board-approved policies covering technology, cybersecurity, and data protection.
- ✓ Technical Controls: Evidence that policies are technically enforced, not just documented.
- ✓ Monitoring & Testing: Proof of ongoing monitoring, vulnerability testing, and control validation.
- ✓ Incident History: Documentation of incidents, response actions, and remediation steps.
- ✓ Training Records: Evidence that staff receive regular training on compliance obligations.
- ✓ Vendor Management: Due diligence documentation for technology service providers.

Common Examination Findings

The most frequent deficiencies cited in regulatory examinations:

- Policies that exist on paper but are not technically enforced or monitored.
- Insufficient evidence of regular security testing and vulnerability management.
- Lack of documented incident response procedures or untested response plans.
- Missing or incomplete vendor risk assessments for critical technology providers.
- Inadequate access controls — shared accounts, missing MFA, excessive privileges.
- No evidence of board or senior management oversight of technology governance.

Examination Readiness Checklist

- Maintain current written supervisory procedures for technology governance
- Document all technical controls with evidence of enforcement
- Keep incident response logs with timeline and remediation details
- Maintain vendor risk assessment files for all technology providers
- Document staff training records with dates and topics covered
- Prepare board-level governance reports showing ongoing oversight
- Conduct annual mock examinations to identify gaps
- Maintain a regulatory change log showing policy updates

Building an Examination-Ready Program

The best examination preparation is an ongoing governance program:

- Continuous compliance monitoring eliminates last-minute examination preparation.
- Automated evidence collection ensures documentation is always current.
- Regular governance reviews identify and remediate gaps before examiners find them.
- Board reporting creates a documented history of oversight and due diligence.
- Managed infrastructure provides technical enforcement evidence automatically.
- The goal is not to prepare for examinations — it is to govern well continuously.